

Security+ 4.5 · Web Filtering

Mestre CyberSec · Aula 4.5 — Web Filtering (10:00) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Web filtering: URL scanning por categoria; content filter; proxy HTTP (intermédia); DNS blocklist (bloqueia na resolução); reputation; bot detection.

💡 Highlights que a prova CompTIA cobra

- DNS blocklist: bloqueia ANTES do browser abrir o site
- Web proxy: intermédia o HTTP/S e pode inspecionar

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'blocks domains at the DNS level'=DNS filtering

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Filtragem de URL (Categorização de URL)

Técnica de filtragem web que classifica sites em categorias (ex.: jogos, malware, redes sociais) e bloqueia ou permite o acesso conforme regras de política.

 **Armadilha CompTIA:** *If the question mentions blocking websites 'by category' (e.g., adult content, gambling), think URL filtering — it relies on an updated URL categorization database.*

• Filtro de Conteúdo (N/A)

Inspecciona o conteúdo real das páginas web (palavras-chave, assinaturas, scripts), em vez de apenas a URL, bloqueando páginas com material proibido ou payloads maliciosos.

 **Armadilha CompTIA:** *Distinguish from URL filtering: URL filter blocks by address/category; content filter blocks by what is *inside* the page (DLP-style keyword matching, malware signatures).*

• Proxy Web (Proxy de Encaminhamento) (HTTP Proxy)

Servidor intermediário que obtém conteúdo web em nome de clientes internos, permitindo cache, registro e inspeção do tráfego HTTP/HTTPS.

 **Armadilha CompTIA:** *Forward proxy = client-side intermediary (outbound traffic); reverse proxy = server-side (inbound). Know both — they appear as distinct answers.*

• Lista de Bloqueio DNS (Sinkhole DNS / Filtragem DNS) (DNSBL)

Bloqueia o acesso a domínios maliciosos ou indesejados impedindo a resolução no nível DNS, de forma que o navegador nunca chega ao site.

 **Armadilha CompTIA:** *Phrasing 'blocks domains at the DNS level' or 'prevents name resolution' = DNS filtering. Key distinction: it blocks *before* the HTTP connection even starts.*

• Filtragem Baseada em Reputação (N/A)

Bloqueia ou permite tráfego com base na pontuação histórica de reputação de um domínio, IP, URL ou arquivo — geralmente mantida por feeds de threat intelligence.

 **Armadilha CompTIA:** *If a question mentions a 'score' or 'threat intelligence feed' being used to decide whether to block a site, the answer is reputation-based filtering — not URL categorization.*

• Detecção de Bots / Filtragem de Bots (N/A)

Identifica e bloqueia tráfego automatizado (bots, scrapers, ferramentas de credential stuffing) usando análise comportamental, CAPTCHA ou fingerprinting.

 **Armadilha CompTIA:** *When the scenario describes unusual request patterns, high-volume automated access, or scraping attempts — the control is bot detection, not standard URL filtering.*

• Inspeção SSL/TLS (Interceptação HTTPS) (SSL Inspection)

Descriptografa, inspeciona e re-criptografa o tráfego HTTPS em um proxy para que a filtragem web e o DLP possam analisar o payload criptografado.

 **Armadilha CompTIA:** *If a question asks how a web proxy 'sees inside HTTPS traffic' — answer is SSL/TLS inspection (MITM proxy). Requires the proxy CA to be trusted by clients.*

Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Numa empresa de logística, os colaboradores estão a passar horas de trabalho em sítios web de jogos de azar e de encontros online. O gestor de TI quer uma solução automatizada que bloqueie classes inteiras de sites, como jogos, apostas e conteúdo para adultos, sem que a equipa de segurança tenha de listar manualmente cada domínio problemático. Que técnica de filtragem web satisfaz melhor este requisito?

- A) Configurar um filtro de conteúdo que analise o texto das páginas à procura de palavras-chave relacionadas com apostas
- B) Aplicar filtragem por categorização de URLs, de modo a bloquear todos os domínios das categorias de apostas e encontros online
- C) Criar regras individuais de firewall por destino (allow/deny) para cada site à medida que é descoberto
- D) Ativar a validação DNSSEC para impedir redirecionamento para domínios não autorizados

QUESTÃO 2 · CENÁRIO DE EXAME

Um analista de segurança de uma empresa industrial está a responder a uma campanha de phishing que utiliza domínios maliciosos recentemente observados. O CISO quer que estes domínios sejam bloqueados para todos os clientes internos o mais cedo possível, antes de qualquer dispositivo sequer tentar estabelecer ligação ao servidor web malicioso. Que implementação cumpre este objetivo?

- A) Uma blocklist de DNS que devolve um endereço sinkhole para cada domínio malicioso listado
- B) Um forward proxy que tem de ser configurado individualmente em cada aplicação cliente
- C) Regras de categorização implantadas como extensões de navegador em cada terminal
- D) Uma política de firewall que permite TCP 443 de saída para todos os destinos, registrando as sessões em log

QUESTÃO 3 · CENÁRIO DE EXAME

O departamento de conformidade de uma seguradora exige que todo o tráfego web gerado pelos colaboradores passe por um único ponto controlado, onde os pedidos podem ser registados, a política da empresa aplicada, as respostas guardadas em cache e o conteúdo devolvido analisado quanto a malware antes de chegar aos clientes. A solução tem de atuar como intermediária em nome dos clientes internos que acedem à internet. Que tecnologia satisfaz estes requisitos?

- A) Um proxy reverso que publica aplicações web internas para parceiros externos
- B) Uma blocklist de DNS que redireciona as consultas a domínios proibidos para um servidor blackhole
- C) Um forward proxy implementado como intermediário de todas as sessões web de saída dos clientes
- D) Uma firewall stateful que faz NAT para todas as ligações de saída da rede local

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa de desenvolvimento de software permite a navegação web geral, mas a equipa de segurança está preocupada com o descarregamento de executáveis maliciosos alojados em sites de aspeto legítimo ou recentemente criados, e com páginas que expõem dados financeiros confidenciais da organização. A proteção tem de inspecionar aquilo que é realmente entregue, como tipos de ficheiro e conteúdo das páginas, independentemente do nome de domínio do site. Que abordagem de filtragem web resolve esta preocupação?

- A) Filtragem por reputação que classifica os domínios com pontuação de risco segundo a sua idade e histórico
- B) Filtragem de conteúdo que inspeciona os tipos de ficheiro e o conteúdo dos objetos web devolvidos
- C) Categorização de URLs que bloqueia categorias inteiras de compras e de partilha de ficheiros
- D) Um sinkhole de DNS que devolve um endereço inválido para domínios sem categoria atribuída

QUESTÃO 5 · CENÁRIO DE EXAME

Depois de instalar um filtro web no perímetro da rede, a equipa de segurança de uma firma de advogados descobre uma lacuna importante: como quase todos os sites usam agora HTTPS, o filtro apenas consegue observar o nome de domínio de destino durante o handshake e não vê o URL completo, o conteúdo das páginas nem os ficheiros devolvidos dentro das sessões cifradas. A administração quer visibilidade completa e aplicação de política sobre o tráfego web cifrado, sem desativar o HTTPS. Que capacidade deve ser implementada?

- A) Forçar os navegadores de volta ao HTTP simples removendo os certificados dos servidores web
- B) Adicionar todos os sites HTTPS atualmente em uso a uma lista de sinkhole de DNS
- C) Bloquear a porta TCP 443 de saída para toda a organização
- D) Inspeção SSL/TLS que decifra as sessões usando um certificado de confiança instalado nos clientes e volta a cifrá-las

QUESTÃO 6 · CENÁRIO DE EXAME

O filtro web de uma empresa farmacêutica baseia-se em listas curadas manualmente e em categorias estáticas, mas os atacantes continuam a registar domínios totalmente novos dias ou mesmo horas antes de os usar em campanhas de phishing e de distribuição de malware, domínios demasiado recentes para figurar em qualquer categoria. O CISO quer que o filtro desconfie automaticamente de domínios com base em fatores como a idade de registo, a atividade histórica e indicadores de threat intelligence. Que funcionalidade fornece este comportamento?

- A) Filtragem por reputação que atribui pontuações de risco aos domínios a partir de fontes de threat intelligence
- B) Filtragem de conteúdo que procura palavras-chave genéricas de phishing nas páginas devolvidas
- C) Detecção de bots que desafia os clientes com testes CAPTCHA antes de servir o conteúdo
- D) Validação DNSSEC que rejeita domínios com registos DNS não assinados

QUESTÃO 7 · CENÁRIO DE EXAME

Os servidores web de um varejista online estão sob forte abuso automatizado: bots de scraping recolhem todo o catálogo de produtos em poucas horas, e scripts de credential stuffing iniciam sessão com milhares de pares de credenciais furtados, imitando navegadores reais. O arquiteto de segurança precisa de um controlo implantado na camada web que distinga clientes automatizados de utilizadores humanos legítimos e bloqueie ou desafie os automatizados. Que solução se aplica?

- A) Ativar regras de categorização de URLs que excluam domínios conhecidos por distribuir ferramentas de scraping
- B) Configurar a blocklist de DNS para que as estações dos atacantes não resolvam o sítio do varejista
- C) Detecção de bots que analisa o comportamento do cliente e emite desafios CAPTCHA ou JavaScript
- D) Implementar um proxy reverso que coloque as páginas de produto estáticas em cache para entrega mais rápida

QUESTÃO 8 · CENÁRIO DE EXAME

Uma universidade implementou filtragem web por DNS, bloqueando categorias ao interceptar todas as consultas enviadas aos seus resolvers internos. Durante uma auditoria, a equipa de rede descobre que os estudantes continuam a chegar a sites de apostas proibidos digitando diretamente no navegador os endereços IP dos sites, ou usando marcadores que dispensam por completo a resolução de nomes. Que controlo adicional fecha esta lacuna de forma mais eficaz?

- A) Um filtro de conteúdo que analise o texto das páginas apenas depois de estas estarem totalmente carregadas
- B) Um forward proxy com filtragem de URL/IP que avalia os destinos mesmo quando não ocorre consulta DNS
- C) Remover o ficheiro hosts local de todos os terminais geridos
- D) Aumentar o TTL da cache DNS dos resolvers internos para reter mais entradas

QUESTÃO 9 · CENÁRIO DE EXAME

Após a implementação da filtragem web por DNS, o SOC de uma empresa de serviços financeiros nota que alguns navegadores geridos nunca recebem páginas de bloqueio: as investigações mostram que esses navegadores estão configurados para usar DNS-over-HTTPS para resolvers públicos, cifrando as consultas de nomes e contornando por completo os servidores DNS internos e as respectivas blocklists. Que mitigação ataca diretamente este contorno, mantendo intacta a política de filtragem por DNS?

- A)** Aumentar os valores de TTL dos registros das zonas DNS internas
- B)** Ativar a assinatura DNSSEC em todas as zonas internas
- C)** Publicar os endereços dos resolvers internos apenas via DHCP em vez de configuração estática
- D)** Bloquear os endpoints públicos conhecidos de DNS-over-HTTPS para que os clientes recaiam nos resolvers internos

QUESTÃO 10 · CENÁRIO DE EXAME

Seis semanas após ativar a inspeção SSL/TLS no filtro web da empresa, o service desk é inundado com relatos de que um portal de apoios do governo e várias aplicações de banca e saúde falham com avisos de certificado ou recusam-se a ligar. A análise mostra que essas aplicações fazem certificate pinning e rejeitam os certificados re-assinados pelo proxy de inspeção. A organização não quer abandonar a inspeção para o restante tráfego. Qual é a remediação mais adequada?

- A)** Desativar a inspeção SSL/TLS em toda a organização e passar a depender apenas da filtragem por categorias
- B)** Pedir a cada banco e portal do governo que inclua o certificado de inspeção da organização na sua whitelist
- C)** Configurar no filtro regras de exceção (bypass) que isentem destinos incompatíveis com a intercepção
- D)** Instalar o certificado raiz do proxy de inspeção diretamente dentro de cada aplicação afetada

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Aplicar filtragem por categorização de URLs, de modo a bloquear todos os domínios das categorias de apostas e encontros online

A categorização de URLs agrupa milhões de domínios em categorias pré-definidas (apostas, conteúdo para adultos, redes sociais, partilha de ficheiros, etc.) mantidas e atualizadas continuamente pelo fornecedor da solução de filtragem. Bloquear categorias inteiras cobre automaticamente todos os domínios incluídos nessa categoria, incluindo os recentemente adicionados, sem trabalho manual-site-a-site. Um filtro de conteúdo por palavras-chave é pouco fiável, não apanha conteúdo não textual e exige primeiro obter a página; regras de firewall por site não escalam e só atuam depois de o site ser descoberto; o DNSSEC apenas valida a integridade/autenticidade das respostas DNS e não impõe qualquer política de navegação.

Questão 2: Alternativa A — Uma blocklist de DNS que devolve um endereço sinkhole para cada domínio malicioso listado

A filtragem por blocklist de DNS atua na fase de resolução de nomes: quando um cliente consulta um domínio malicioso presente na lista, o resolver interno devolve um endereço sinkhole (por exemplo, 127.0.0.1 ou um servidor blackhole dedicado) em vez do IP real. Como a ligação nunca chega a ser estabelecida, a ameaça é travada na fase mais inicial do fluxo e a proteção é aplicada automaticamente a todos os dispositivos que usam os resolvers internos. Um forward proxy só vê o tráfego que lhe é encaminhado e normalmente exige configuração por aplicação; extensões de navegador dependem do terminal e são fáceis de contornar; uma política que permita todo o HTTPS de saída apenas regista as ligações, deixando mesmo assim alcançar a infraestrutura de phishing.

Questão 3: Alternativa C — Um forward proxy implementado como intermediário de todas as sessões web de saída dos clientes

Um forward proxy fica entre os clientes internos e a internet: recebe os pedidos em nome dos clientes, aplica políticas de URL e de conteúdo, regista a atividade, guarda respostas em cache e pode analisar o conteúdo devolvido antes de o entregar. Este papel de intermediário do tráfego de saída dos utilizadores é exatamente o que a conformidade exige. Um proxy reverso tem a função oposta, sendo colocado à frente de servidores internos para tratar do tráfego de entrada vindo da internet; uma blocklist de DNS apenas impede a resolução de nomes proibidos e não oferece inspeção nem registo do tráfego geral; o NAT numa firewall stateful altera endereços, mas não intervém nem inspeciona pedidos web ao nível da aplicação.

Questão 4: Alternativa B — Filtragem de conteúdo que inspeciona os tipos de ficheiro e o conteúdo dos objetos web devolvidos

A filtragem de conteúdo examina os dados realmente entregues na sessão web, incluindo o texto das páginas, os scripts e os tipos de ficheiro, como descarregamentos de executáveis, e pode bloquear com base nesse conteúdo independentemente do domínio que o serve. Isto apanha ficheiros maliciosos alojados em sites benignos ou recém-criados, sobre os quais as categorias ou os dados de reputação ainda não dizem nada, e permite ainda detetar padrões de dados confidenciais no conteúdo das páginas. A filtragem por reputação avalia apenas a pontuação de risco do domínio; a categorização de URLs decide pela classe a que o site pertence, não pelo que serve; colocar em sinkhole todos os domínios sem categoria ou bloquearia boa parte da internet legítima ou deixaria de inspecionar o conteúdo dos sites já permitidos.

Questão 5: Alternativa D — Inspeção SSL/TLS que decifra as sessões usando um certificado de confiança instalado nos clientes e volta a cifrá-las

A inspeção SSL/TLS permite ao proxy ou filtro terminar a sessão TLS do cliente, decifrá-la com certificados emitidos por uma CA raiz/intermédia tornada fidedigna pela organização nos seus terminais, inspecionar o URL e o conteúdo em texto claro, aplicar a política e voltar a cifrar o tráfego para o destino real. Assim recupera-se a visibilidade sobre o URL completo e o conteúdo entregue, mantendo a encriptação entre o dispositivo de inspeção e o site. Recuar para HTTP é inseguro, irrealista e quebra os sites modernos; colocar todos os sites HTTPS em sinkhole apenas os bloquearia, sem dar visibilidade; bloquear a porta 443 eliminaria simplesmente a utilização moderna da web.

Questão 6: Alternativa A — Filtragem por reputação que atribui pontuações de risco aos domínios a partir de fontes de threat intelligence

A filtragem por reputação consome inteligência continuamente atualizada sobre cada domínio, incluindo a idade de registo, o comportamento histórico, as características WHOIS e as aparições em feeds de threat intelligence, para calcular uma pontuação de risco. O filtro pode então bloquear ou alertar automaticamente sobre domínios de má reputação, incluindo os recém-registados que nenhuma categoria lista ainda. A procura de palavras-chave de phishing é falível e exige primeiro carregar a página; os desafios CAPTCHA separam humanos de bots, mas nada dizem sobre a fiabilidade do domínio visitado; o

DNSSEC valida a integridade e autenticidade dos dados DNS, e um domínio de phishing perfeitamente assinado continua malicioso.

Questão 7: Alternativa C — Detecção de bots que analisa o comportamento do cliente e emite desafios CAPTCHA ou JavaScript

A detecção/filtragem de bots examina as características e o comportamento do cliente, incluindo user agents, assinaturas de navegadores headless, ausência de padrões de interação humana, e taxas e sequências de pedidos, separando os bots dos utilizadores reais e respondendo com desafios como CAPTCHA ou testes JavaScript, bloqueando quem falhar. É exatamente o controlo na camada web pedido para distinguir clientes automatizados de humanos. A categorização de URLs classifica sites de terceiros, não os clientes que visitam o varejista; uma blocklist de DNS impede a resolução de domínios maliciosos e não atua sobre os IPs de origem dos atacantes; um proxy reverso com cache melhora o desempenho e amortece a carga do scraping, mas não identifica nem bloqueia os clientes automatizados.

Questão 8: Alternativa B — Um forward proxy com filtragem de URL/IP que avalia os destinos mesmo quando não ocorre consulta DNS

A filtragem por DNS só pode influenciar nomes que sejam efetivamente resolvidos através dos servidores DNS internos. Ligações feitas diretamente por endereço IP nunca originam uma consulta DNS, pelo que a blocklist nunca é consultada. Um forward proxy por onde todo o tráfego web de saída é forçado a passar aplica política de URL e de IP sobre a própria ligação, verificando o endereço de destino e o cabeçalho Host, fechando assim o contorno por IP direto que a filtragem apenas por DNS não cobre. Uma análise de conteúdo posterior ao carregamento ainda deixa a ligação suceder e implica renderizar conteúdo potencialmente perigoso; o ficheiro hosts não tem relação com navegação por IP literal; aumentar o TTL da cache apenas prolonga a retenção de entradas e não resolve o contorno.

Questão 9: Alternativa D — Bloquear os endpoints públicos conhecidos de DNS-over-HTTPS para que os clientes recaiam nos resolvers internos

O DoH transporta as consultas DNS dentro de sessões HTTPS dirigidas a fornecedores externos, pelo que os servidores internos nunca são consultados e as suas blocklists deixam de se aplicar. Os serviços DoH públicos conhecidos, identificáveis pelos nomes de domínio e endereços dos resolvers, podem eles próprios ser bloqueados pelo filtro web ou pela firewall, e a maioria dos produtos de filtragem DNS inclui esses endpoints nas blocklists por omissão. Com o DoH externo bloqueado, os navegadores em modo de recurso automático passam novamente a usar o resolver do sistema, restaurando a política interna de filtragem. Alterar TTLS só afeta a duração da cache; o DNSSEC não impede consultas cifradas a fornecedores externos; distribuir os resolvers via DHCP não impede que utilizadores ou navegadores configurem DoH externo por conta própria.

Questão 10: Alternativa C — Configurar no filtro regras de exceção (bypass) que isentem destinos incompatíveis com a interceção

As aplicações com certificate pinning recusam qualquer certificado que não seja exatamente o esperado pelo pin, incluindo os certificados re-assinados por um dispositivo de inspeção, e a organização não tem qualquer autoridade sobre os pins incorporados no software de bancos e portais governamentais externos. A prática aceite é manter uma lista de exclusões/bypass de inspeção para os destinos incompatíveis com a interceção, como aplicações com pinning e, por política e privacidade, categorias como banca e saúde, mantendo a inspeção em todo o restante tráfego. Desativar a inspeção em toda a empresa remove a visibilidade e a aplicação de política sobre todo o tráfego; os operadores externos não irão incorporar o certificado de uma organização cliente no seu pinning; instalar a raiz da CA dentro da aplicação não muda nada, porque o pinning valida o certificado apresentado contra o valor fixado na aplicação, e o certificado re-assinado continua a falhar essa comparação.